La sensibilisation au RGPD

Tous droits réservés à STUDI - Reproduction interdite

Table des matières

I - Contexte **3**

II - Présentation, explication **4**

A. Le rôle du RGPD 4

B. La portée du RGPD 5

III - Comprendre le rôle de la CNIL **6**

A. Présentation 6

B. La réglementation et le pouvoir de la CNIL 7

IV - Comprendre le rôle du DPO **9**

A. Présentation 9

B. La réglementation et les responsabilités du DPO 10

V - L'essentiel **11**

VI - Auto évaluation **12**

A. Exercice 12

B. Test 12

Solutions des exercices **14**

Tous droits réservés à STUDI - Reproduction interdite

I Contexte

Contexte

La protection des données personnelles est au centre de l'actualité depuis plusieurs années déjà. Depuis l'avènement des nouvelles technologies, les pratiques de collecte et de traitement des données ont beaucoup évolué. Ceci a donc commencé à poser des questions légales. Forte de ce constat, en 1995, l'Union européenne a créé la première réglementation sur la protection des données. Il s'agit de la directive 95/46/CE. Celle-ci a fixé les premières règles en matière de traitement des données personnelles en Europe. Bien que la directive ait été une avancée importante pour la protection des données personnelles, celle-ci a rapidement montré ses limites face à l'évolution rapide des technologies numériques et des pratiques de collecte et de traitement des données.

C'est la raison pour laquelle la Commission européenne a proposé une réforme de la protection des données. Cette proposition avait pour objectif de renforcer la législation précédente. Cette proposition a abouti à la création du Règlement général sur la protection des données, ou RGPD, qui a été adopté le 25 mai 2018. Cette réglementation s'applique à toutes les entreprises qui collectent, stockent et traitent les données personnelles des citoyens européens.

En comprenant l'histoire et les enjeux de la création du RGPD, vous pourrez mieux comprendre les principes et les obligations de cette réglementation. Cela peut également permettre de mieux sensibiliser vos collaborateurs à la mise en place des processus nécessaires pour se conformer aux règles de protection des données personnelles.

Tous droits réservés à STUDI - Reproduction interdite

II Présentation, explication

A. Le rôle du RGPD

Fondamental

Le rôle principal du RGPD est de protéger les droits fondamentaux des citoyens européens en matière de vie privée et de protection des données personnelles. Voyons à présent les principales règles qui régissent le Règlement général sur la protection des données.

Premièrement, le **consentement**. Les entreprises doivent obtenir un consentement explicite et sans contrainte de l'utilisateur avant de collecter et de traiter ses données personnelles. Son consentement doit obligatoirement être spécifique, informé et donné sans pression ni manipulation. Aussi, les entreprises doivent informer la personne de son droit de supprimer ou de modifier ses informations personnelles dans la base de données, à tout moment.

De plus, les entreprises doivent annoncer la **finalité de l'utilisation** des données. Elles doivent collecter et traiter les données personnelles uniquement pour des objectifs spécifiques, légitimes et clairement énoncés. Les entreprises doivent informer la personne en question de ces objectifs et ne peuvent pas utiliser les données à d'autres fins sans obtenir un nouveau consentement. Les entreprises ont également l'obligation de s'assurer que les objectifs ne sont pas contraires à la loi ou aux droits et aux libertés fondamentales de la personne.

Ensuite, il y a le principe de la **minimisation** des données. Le RGPD indique que les entreprises doivent uniquement collecter des données personnelles nécessaires afin d'atteindre les objectifs spécifiques pour lesquels elles ont été collectées. Par ailleurs, elles n'ont pas le droit de collecter de données excessives ou inutiles. Elles doivent également prendre des mesures afin d'anonymiser ou de pseudonymiser les données personnelles lorsque cela est possible.

Il y a également le principe de **l'exactitude**. Les entreprises doivent s'assurer que les données personnelles collectées soient exactes, tenues à jour et conservées de manière appropriée et sécurisée. Les personnes dont les données ont été collectées ont également le droit de demander la correction ou la suppression de leurs données personnelles qu'elles jugent inexactes ou incomplètes. Les entreprises doivent également prendre des mesures permettant de garantir que les données personnelles seront effacées ou corrigées dans un délai raisonnable.

Un autre principe important concerne la **limitation de la conservation**. Ce dernier implique que les entreprises doivent conserver les données personnelles uniquement pendant une durée limitée, et ceci en fonction des objectifs pour lesquels elles ont été collectées. Ainsi, les entreprises doivent établir une politique de conservation des données et supprimer les données qui ne sont plus nécessaires. Les entreprises peuvent également supprimer les données personnelles si la personne en question décide de retirer son consentement ou si les données collectées ne sont plus nécessaires pour les objectifs spécifiques pour lesquels elles ont été collectées.

Dernier axe et pas des moindres : la **sécurité** des données. Les entreprises doivent mettre en place des mesures techniques et organisationnelles afin de protéger les données personnelles contre le vol ou la divulgation non autorisée. Par ailleurs, les entreprises doivent signaler les violations de données à l'autorité du contrôle et aux personnes concernées dans les 72 heures suivant leur découverte. Les entreprises doivent également tenir un registre des violations de données et mettre en place des mesures pour prévenir de telles violations.

Tous droits réservés à STUDI - Reproduction interdite

Remarque

Il est important de noter que les entreprises doivent être en mesure de démontrer leur conformité au RGPD. Ceci est possible en documentant leurs politiques, procédures et mesure de sécurité concernant la protection des données personnelles. Pour réaliser cette tâche, les entreprises doivent également nommer un Délégué à la Protection des Données (DPO), si celles-ci traitent des données personnelles à grande échelle ou si elles traitent des données sensibles telles que des données de santé, par exemple.

Attention

Toute entreprise qui traite des données personnelles de citoyens européens, qu'elles soient basées dans l'Union européenne ou non, est concernée par le RGPD. En cas de non-respect du RGPD, les entreprises risquent des amendes très lourdes pouvant atteindre 20 millions d'euros ou 4 % de leur chiffre d'affaires annuel.

Cette réglementation a un impact majeur. En effet, elle protège les droits fondamentaux des citoyens européens en matière de vie privée et de protection des données personnelles. Les entreprises doivent s'engager à respecter les principales règles du RGPD afin de garantir la confidentialité, l'intégrité et la disponibilité des données personnelles qu'elles collectent, utilisent et stockent. Les entreprises doivent également être en mesure de démontrer leur conformité au RGPD et prendre des mesures afin de prévenir les violations de données, ainsi que signaler rapidement les violations qui se produisent.

B. La portée du RGPD

Tous droits réservés à STUDI - Reproduction interdite

III Comprendre le rôle de la CNIL

A. Présentation

Az Définition

En France, l'organisme chargé de la mise en place du RGPD est la Commission Nationale de l'Informatique et des Libertés (CNIL). Cet organisme a pour mission de protéger les citoyens français contre les abus ainsi que les violations de la vie privée en matière de traitement des données personnelles. La CNIL est également chargée de faire respecter le RGPD en France en vérifiant que les entreprises respectent les obligations associées.

Par ailleurs, la CNIL a le pouvoir de **contrôler** les entreprises, de leur donner des **avertissements**, mais aussi des **sanctions** en cas de non-respect du RGPD. Elle peut également lancer des enquêtes et des audits sur des entreprises afin de s'assurer que les obligations de la réglementation sont respectées. Mais le RGPD n'affecte pas uniquement les entreprises européennes ! En effet, les entreprises en dehors de l'Union européenne qui traitent les données personnelles des citoyens européens doivent également respecter les obligations du RGPD.

Si elles proposent des biens ou services à des citoyens européens, ces entreprises doivent donc être très attentives aux exigences du RGPD afin d'éviter des sanctions financières et préserver leur réputation.

L'affaire Facebook-Cambridge Analytica

Exemple

Facebook a été accusé d'avoir divulgué les données personnelles de 2,7 millions d'utilisateurs européens et 87 millions d'utilisateurs dans le monde. Cette affaire a grandement entaché la réputation du réseau social et donc la confiance des utilisateurs envers celui-ci.

La loi française informatique et libertés

Az Définition

La loi française « *informatique et libertés* » est la première loi sur la protection des données personnelles adoptée en Europe. Celle-ci a été adoptée en 1978. Son but était simple : protéger les citoyens français contre l'utilisation abusive des données personnelles à leur sujet. Cette loi a établi des règles très claires entourant la collecte, le traitement ainsi que la conservation des données personnelles.

Elle a notamment créé la CNIL afin de superviser la mise en pratique de ladite loi et afin de s'assurer la protection des données personnelles. Pour lire le texte de loi complet, il vous suffit de taper : « *Loi n° 78-17 du 6 janvier 1978 relative à l'informatique, aux fichiers et aux libertés* » dans votre moteur de recherche. Celle-ci comporte 38 articles détaillant les dispositions quant à la collecte, le traitement, la conservation et la communication des données personnelles et les droits des personnes concernées. Mais aussi, les obligations des responsables de traitement, les sanctions en cas de non-respect de la loi et les attributions et missions de la CNIL.

Tous droits réservés à STUDI - Reproduction interdite

En plus de sa possibilité de contrôler et de sanctionner les entreprises qui ne respectent pas le RGPD, la CNIL tient également un rôle important dans la sensibilisation ainsi que l'accompagnement des entreprises afin de les aider à respecter les obligations légales en matière de protection des données personnelles. Elle met notamment à disposition de nombreuses **ressources en ligne**, comme des guides pratiques et des modèles de documents, afin d'aider les entreprises à se mettre en conformité avec la réglementation. Elle organise aussi des **événements** et des **formations** d'entreprise dans le but d'informer celles-ci des dernières évolutions en matière de la protection des données.

Enfin, la CNIL travaille en étroite collaboration avec d'autres autorités de régulation européennes afin d'assurer une bonne application du RGPD au niveau de l'Union européenne. Il est clair que la CNIL joue un rôle primordial dans la protection des données personnelles des citoyens français, car elle veille à ce que les entreprises et organisations respectent les obligations légales en matière de protection des données, et elle s'assure qu'elles mettent en place toutes les mesures nécessaires afin de protéger les droits et libertés de chacun. La CNIL est un partenaire essentiel afin d'accompagner les entreprises dans leur démarche de protection des données personnelles, et de conformité.

En plus des événements à destination des professionnels, celle-ci organise régulièrement des **campagnes de sensibilisation** afin d'informer les citoyens sur les risques liés à l'utilisation de leurs données personnelles et de les sensibiliser aux bonnes pratiques qu'ils devraient adopter. Eux aussi ont accès à des ressources en lignes afin de les aider à mieux comprendre leurs droits en matière de protection des données personnelles.

Qu’est-ce que la CNIL ?

Dans cette vidéo, découvrez plus en détail quel est le rôle de la CNIL.

B. La réglementation et le pouvoir de la CNIL

Comme nous l’avons vu précédemment, la CNIL est l'autorité chargée de protéger les données personnelles en France. Elle joue donc un rôle central dans la promotion de la sensibilisation à la protection des données auprès du grand public grâce à l'ensemble des mesures qu'elle met en place et aux campagnes de sensibilisation qu'elle mène auprès du grand public. Parmi elles, nous pouvons citer quelques-unes de plus emblématiques.

En 2009, la CNIL a lancé une campagne de sensibilisation sur le **droit à l'oubli numérique**. Cette campagne visait à informer sur le droit de demande à la suppression de données personnelles obsolètes ou inexactes ainsi que des pistes pour exercer ce droit.

En 2017, elle a lancé une campagne de sensibilisation sur la protection des données personnelles lors de la Journée mondiale de la protection des données, afin de fournir des conseils pour améliorer la sécurité des données. Lors de cette action, elle a notamment rappelé l’importance de créer des mots de passe solides pour ses comptes en ligne et a proposé un kit de ressources-outils afin de mieux les concevoir et les gérer.

Enfin, en 2021, elle a lancé une campagne de sensibilisation sur les cookies destinée aux acteurs privés et publics.

En plus de ces actions, la CNIL est également chargée de surveiller le développement en matière de protection des données, ainsi que de conseiller les organismes publics et privés quant aux questions relatives à la protection des données personnelles. Par ailleurs, elle est le point de contact unique pour la coopération entre les autorités de protection des données dans l'Union européenne.

Tous droits réservés à STUDI - Reproduction interdite

Remarque

Grâce à l'ensemble de ces mesures, la CNIL peut veiller à la protection des données personnelles des citoyens Français. Cet enjeu est de plus en plus crucial suite au développement des nouvelles technologies. L'ensemble des mesures imposées aux entreprises peut sembler lourd, mais ces mesures sont néanmoins cruciales afin de garantir la protection des données et surtout, de protéger les droits et libertés de chacun.

Pour obtenir plus d'informations sur la CNIL, vous pouvez consulter leur site officiel : CNIL[1].

1. https://www.cnil.fr/fr

Tous droits réservés à STUDI - Reproduction interdite

IV Comprendre le rôle du DPO

A. Présentation

Le DPO (Délégué à la protection des données) joue un rôle clé dans la mise en place du RGPD. En effet, comme nous l'avons vu précédemment, les entreprises et organisations qui traitent une grande quantité de données personnelles ou qui traitent des données sensibles telles que des informations médicales sont dans l'obligation de nommer un DPO, selon les règles du RGPD.

Mais quel est le rôle d'un DPO exactement ? Son rôle principal est de veiller à ce que l'entreprise ou organisation **respecte le RGPD** et **protège les droits des personnes** concernées efficacement. Pour ce faire, celui-ci doit avoir des compétences en matière de protection des données, et être en mesure d'évaluer les risques pour les droits et les libertés des personnes. Il doit également travailler en étroite collaboration avec les équipes chargées de la sécurité dans l'entreprise, ceci dans le but de garantir une protection efficace des données personnelles.

Par ailleurs, ses responsabilités légales sont multiples. Premièrement, il doit **conseiller les entreprises et organisations** sur les questions liées à la protection des données. En effet, il doit définir les politiques ainsi que les procédures liées à la gestion des données personnelles. Il doit également **analyser la conformité** des processus de traitement des données de l'entreprise et **recommander des mesures** de sécurité adéquates.

Deuxièmement, il doit surveiller la conformité de l'entreprise ou de l'organisation et les politiques internes à l'entreprise en matière de protection des données avec le RGPD. Il doit notamment s'assurer que l'entreprise met en œuvre les bonnes **mesures de sécurité**. Parmi elles, il y a la gestion des consentements, l'identification ainsi que la correction des erreurs dans les données personnelles des utilisateurs. Le DPO doit aussi pouvoir signaler les incidents en matière de violation de données à une autorité de contrôle, comme la CNIL, ainsi que coopérer avec elle tout au long de l'enquête.

Il doit également être le **point de contact** pour les autorités de contrôle ainsi que les utilisateurs concernés en matière de protection des données. Par exemple, il doit répondre aux questions ainsi qu'aux préoccupations des personnes concernant le traitement de leurs données personnelles. Ayant également le rôle de **médiateur** entre les autorités de contrôle et les entreprises, le DPO doit notamment s'assurer que l'entreprise ou l'organisation répond convenablement aux préoccupations concernant les données personnelles.

Son rôle est également de **sensibiliser les employés** de l'entreprise au RGPD ainsi qu'à la protection des données personnelles. Il est dans l'obligation de fournir une formation aux employés de l'entreprise afin de les aider à comprendre les tenants et les aboutissants de la protection des données, et ce, de manière régulière.

Remarque

Comme nous avons pu le constater, le DPO a de nombreuses responsabilités. Cependant, tout ne dépend pas de lui. En effet, celui-ci n'est pas responsable de la mise en œuvre du RGPD au sein de l'organisation. Il agit plutôt comme un conseiller et il est également chargé de surveiller la mise en œuvre des mesures liées au RGPD. La responsabilité de la mise en œuvre du RGPD incombe à l'entreprise et à elle seule.

Tous droits réservés à STUDI - Reproduction interdite

Enfin, afin de remplir efficacement son rôle, il est important que celui-ci dispose de **ressources**, ainsi que de la **liberté** nécessaire à l'exercice de son métier de manière autonome et sans être influencé par qui que ce soit dans l'organisation. De ce fait, les entreprises et organisations doivent mettre en place un ensemble de procédures afin de lui permettre de remplir efficacement son rôle, comme l'octroi de ressources telles que des outils et des logiciels de gestion.

Pour finir, le DPO doit travailler en étroite collaboration avec les autres parties prenantes de l'organisation, afin de s'assurer de la conformité des actions avec le RGPD. Le DPO doit notamment être en mesure de communiquer efficacement avec les équipes de sécurité, de conformité et de technologie de l'entreprise afin de veiller à ce que les politiques et les procédures de protection des données soient appliquées dans toute l'entreprise de manière cohérente. Pour obtenir plus de renseignements sur le rôle du DPO, voici un article de la CNIL : CNIL[2].

B. La réglementation et les responsabilités du DPO

2. https://www.cnil.fr/fr/delegues-la-protection-des-donnees-la-cnil-et-ses-homologues-europeens-procedent-une-serie-de

Tous droits réservés à STUDI - Reproduction interdite

V L'essentiel

Le RGPD est le résultat d'un processus de négociation conséquent qui a impliqué les institutions européennes, les États membres de l'UE et même des parties prenantes de la société civile.

La création du RGPD a eu plusieurs effets. Premièrement, l'adoption du RGPD a renforcé les droits des citoyens européens au sujet de leurs données personnelles. Deuxièmement, le RGPD a imposé des obligations plus strictes aux entreprises qui traitent des données personnelles de citoyens européens.

Ensuite, ce règlement a permis aux citoyens de contrôler leurs données personnelles d'une meilleure manière. Il a également permis aux citoyens européens de bénéficier de plus de transparence quant au traitement et à la collecte de leurs données personnelles.

En outre, ce règlement a imposé aux entreprises de respecter les principes de transparence, de sécurité et de respect de la vie privée des citoyens européens et en France, l'organisme de contrôle chargé d'assurer leur respect est la CNIL.

En effet, le RGPD repose sur 6 principes clés que sont le consentement des utilisateurs, la finalité de la récolte des données, la minimisation des données, l'exactitude, la limitation de la conservation, ainsi que la sécurité des données comme nous l'avons vu tout au long du cours.

Ces principes ont pour but de renforcer la protection des données personnelles des citoyens européens, et de garantir que ces données sont traitées de manière équitable et transparente.

Enfin, grâce au RGPD, un nouveau rôle dans les entreprises a également été créé. Il s'agit de celui de délégué à la protection des données, ou DPO, dont le rôle est de veiller au respect des règles de protection des données personnelles au sein de l'entreprise et de s'assurer que les données personnelles sont traitées de manière conforme au RGPD.

En résumé, le RGPD est une réglementation européenne cruciale qui vise à protéger les données personnelles des citoyens européens. Il est important de comprendre les principes clés, les droits des utilisateurs, mais aussi les obligations des responsables de traitement des données ainsi que les bonnes pratiques. Tout ceci permettra d'assurer la conformité de l'organisation au RGPD.

Tous droits réservés à STUDI - Reproduction interdite

VI Auto évaluation

A. Exercice

Vous travaillez pour une entreprise française qui traite des données personnelles sensibles, comme des informations médicales. Vous êtes le DPO de l'entreprise et vous êtes chargé de garantir que l'entreprise est conforme au RGPD. Un jour, un employé de l'entreprise signale une violation de données. Celui-ci affirme que des informations sensibles ont été divulguées à un organisme tiers non autorisé.

Question 1

[solution n°1 p. 14]

En tant que DPO, que devez-vous faire ?

Question 2

[solution n°2 p. 14]

Quel est le rôle de la CNIL dans cette situation et quelles actions pourrait-elle mettre en place ?

B. Test

Exercice 1 : Quiz

[solution n°3 p. 14]

Question 1

Quel est le rôle principal du RGPD ?

- Encourager les entreprises à collecter plus de données personnelles
- Protéger les données personnelles des personnes
- Réduire la concurrence entre les entreprises

Question 2

Quels sont les principes clés du RGPD ?

- La finalité, la minimisation des données et la sécurité
- Le consentement, l'expression et la sécurité
- L'exactitude, la limitation de la conservation et l'expression
- Le consentement, la finalité, la minimisation et l'exactitude des données, la limite de conservation et la sécurité des données

Question 3

Qu'est-ce qu'un DPO ?

- Un responsable de traitement

Tous droits réservés à STUDI - Reproduction interdite

Un représentant de la CNIL

Un délégué à la protection des données personnelles

Question 4

Qu'est-ce que la CNIL ?

Un cabinet d'avocats spécialisé dans la protection des données personnelles

Une entreprise spécialisée dans le traitement des données personnelles

Un organisme de réglementation des données personnelles

Question 5

Quelles entreprises ont l'obligation d'embaucher un DPO ?

Les grandes entreprises

Les entreprises qui traitent de grandes quantités de données ou des données sensibles

Toute entreprise qui traite et collecte des données

Tous droits réservés à STUDI - Reproduction interdite

Solutions des exercices

[exercice p. 12] Solution n°1

Dans cette situation, en tant que DPO, il est important de prendre des mesures immédiates pour gérer la violation de données signalée. Les étapes sont les suivantes :

1. Examiner la violation signalée : il est important de comprendre l'ampleur de la violation signalée et les informations qui ont été divulguées.
2. Évaluer l'impact : il faut déterminer si la violation est susceptible d'entraîner un risque pour les droits et libertés des personnes concernées.
3. Notifier la CNIL : si la violation est susceptible d'entraîner un risque élevé pour les droits et libertés des personnes concernées, il faut notifier la CNIL.
4. Informer les personnes concernées : si la violation est susceptible d'entraîner un risque élevé pour les droits et libertés des personnes concernées, il faut également informer les personnes concernées par la violation.
5. Prévention : il est important de prendre des mesures pour empêcher que la violation se reproduise à l'avenir.

[exercice p. 12] Solution n°2

Le rôle de la CNIL est de veiller à l'application du RGPD et à ce que les organisations respectent les règles de protection des données. Dans cette situation, la CNIL peut mener une enquête afin de déterminer si l'entreprise a respecté les règles du RGPD. Celle-ci peut notamment imposer des sanctions si elle constate que certaines règles n'ont pas été respectées, notamment si cela a entraîné la violation des données. Une coopération du DPO avec la CNIL sera nécessaire tout au long de la gestion de la violation signalée.

Solution n°3

[exercice p. 12]

Question 1

Quel est le rôle principal du RGPD ?

- Encourager les entreprises à collecter plus de données personnelles
- ✓ Protéger les données personnelles des personnes
- Réduire la concurrence entre les entreprises

En effet, le RGPD a été créé afin de protéger les données personnelles des personnes et garantir que leur vie privée est respectée dans un monde de plus en plus connecté.

Question 2

Quels sont les principes clés du RGPD ?

Tous droits réservés à STUDI - Reproduction interdite

La finalité, la minimisation des données et la sécurité

Le consentement, l'expression et la sécurité

L'exactitude, la limitation de la conservation et l'expression

✓ Le consentement, la finalité, la minimisation et l'exactitude des données, la limite de conservation et la sécurité des données

En effet, ces principes sont au cœur du RGPD et doivent être respectés par les entreprises qui traitent des données personnelles.

Question 3

Qu'est-ce qu'un DPO ?

Un responsable de traitement

Un représentant de la CNIL

✓ Un délégué à la protection des données personnelles

Le DPO est bien un conseiller des entreprises. Il accompagne les organisations quant aux questions concernant la protection des données personnelles et supervise la conformité de celles-ci.

Question 4

Qu'est-ce que la CNIL ?

Un cabinet d'avocats spécialisé dans la protection des données personnelles

Une entreprise spécialisée dans le traitement des données personnelles

✓ Un organisme de réglementation des données personnelles

En effet, la CNIL est l'autorité de régulation française en matière de protection des données personnelles. Elle est chargée de superviser la mise en œuvre du RGPD en France et de veiller à ce que les entreprises respectent les règles en matière de protection des données personnelles.

Question 5

Quelles entreprises ont l'obligation d'embaucher un DPO ?

Tous droits réservés à STUDI - Reproduction interdite

Les grandes entreprises

✓ Les entreprises qui traitent de grandes quantités de données ou des données sensibles

Toute entreprise qui traite et collecte des données

En effet, seules les entreprises qui traitent de grandes quantités de données ou des données sensibles comme des données médicales, par exemple, sont dans l'obligation d'embaucher un DPO.

Tous droits réservés à STUDI - Reproduction interdite